

Федеральное государственное автономное образовательное учреждение
высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность
**Работа 1: Разработка защищенного REST API с
интеграцией в CI/CD**

Выполнил:

Баянов Равиль Динарович

Группа:

P3434

г. Санкт-Петербург

2025

Содержание

ССЫЛКА НА ПУБЛИЧНЫЙ GIT-РЕПОЗИТОРИЙ (GITHUB/GITLAB) С КОДОМ ПРОЕКТА	3
ТЕСТИРОВАНИЕ ПРИЛОЖЕНИЯ	10
ФАЙЛ README.MD В РЕПОЗИТОРИИ	4
ССЫЛКА НА ПОСЛЕДНИЙ УСПЕШНЫЙ ЗАПУСК PIPELINE В ВАШЕМ РЕПОЗИТОРИИ	13
ВЫВОД	14

Ссылка на публичный git-репозиторий (GitHub/GitLab) с кодом проекта

<https://github.com/RavvChek/lab1>

Файл README.md в репозитории

Information Security Lab #1

Описание проекта

Данный проект представляет из себя веб-приложение, демонстрирующее современные практики веб-безопасности, реализуя с помощью Java/Spring:

- JWT-аутентификация.
- Валидация входных данных для предотвращения XSS атак.
- ORM запросы для предотвращения использования SQL-инъекции.
- Конфигурация на основе переменных окружения для безопасного развёртывания приложения.

Методы API

1. POST /auth/login -- Аутентификация пользователя

Описание:

Метод принимает логин и пароль пользователя. В случае успешной аутентификации возвращает JWT-токен.

Request:

POST /auth/login

```
{
  "username": "user",
  "password": "password"
}
```

```
{  
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTJ5IiwiaWF0IjoxNTE2MjY5MDAifQ=="  
}
```

— — —

Request:

GET /api/data

Authorization: Bearer <JWT>

Response (JSON):

```
...  
[  
  {  
    "id": 0,  
    "name": "name",  
    "author": "author",  
    "numberOfPLays": 0,  
  }  
]  
...
```

Ошибки:

* 403 Forbidden -- если отсутствует или невалиден JWT.

3. POST /api/data -- Добавление нового трека

Описание:

Добавляет новую сущность Track в список. Доступ только для аутентифицированных пользователей.

Request:

POST /api/data

Authorization: Bearer <JWT>

...

```
{  
  "name": "name",  
  "author": "author",  
  "numberOfPlays": 0
```

```
}
```

...

Response:

OK

Ошибки:

* 400 Bad Request -- если данные невалидны.

* 403 Forbidden -- если отсутствует или невалиден JWT.

Меры защиты

API использует JWT-токены для защиты эндпоинтов.

- * Пользователь проходит аутентификацию через POST /auth/login.
- * В ответ получает accessToken (JWT).
- * Для доступа к защищённым эндпоинтам необходимо передавать токен в заголовке:

Authorization: Bearer <JWT>

Противодействие SQL Injection (SQLi)

- * Используется Spring Data JDBC, который применяет параметризованные запросы → данные подставляются безопасно, без конкатенации SQL-строк.
- * Таким образом, классические SQLi невозможны.

Противодействие XSS

- * REST API возвращает только JSON и не исполняет JavaScript.
- * Устанавливаются заголовки HTTP X-XSS-Protection: 1; mode=block и Content-Security-Policy: script-src 'self'

Реализация аутентификации

- * Используется JWT-токен, который подписывается секретным ключом.
- * Токен проверяется middleware (Spring Security OncePerRequestFilter).
- * Без токена доступ к защищённым эндпоинтам запрещён.

Скриншот отчета OWASP



Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies. false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | [Getting Help: github issues](#)

[Sponsor](#)

Project: lab1

ru.ravvcheck:lab1:0.0.1-SNAPSHOT

Scan Information ([show all](#)):

- dependency-check version: 12.1.3
- Report Generated On: Sun, 19 Oct 2025 14:03:36 GMT
- Dependencies Scanned: 76 (49 unique)
- Vulnerable Dependencies: 0
- Vulnerabilities Found: 0
- Vulnerabilities Suppressed: 0
- ...

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
------------	-------------------	---------	------------------	-----------	------------	----------------

Dependencies (vulnerable)

This report contains data retrieved from the [National Vulnerability Database](#).
This report may contain data retrieved from the [CISA Known Exploited Vulnerability Catalog](#).
This report may contain data retrieved from the [Github Advisory Database \(via NPM Audit API\)](#).
This report may contain data retrieved from [RetireJS](#).
This report may contain data retrieved from the [Sonatype OSS Index](#).

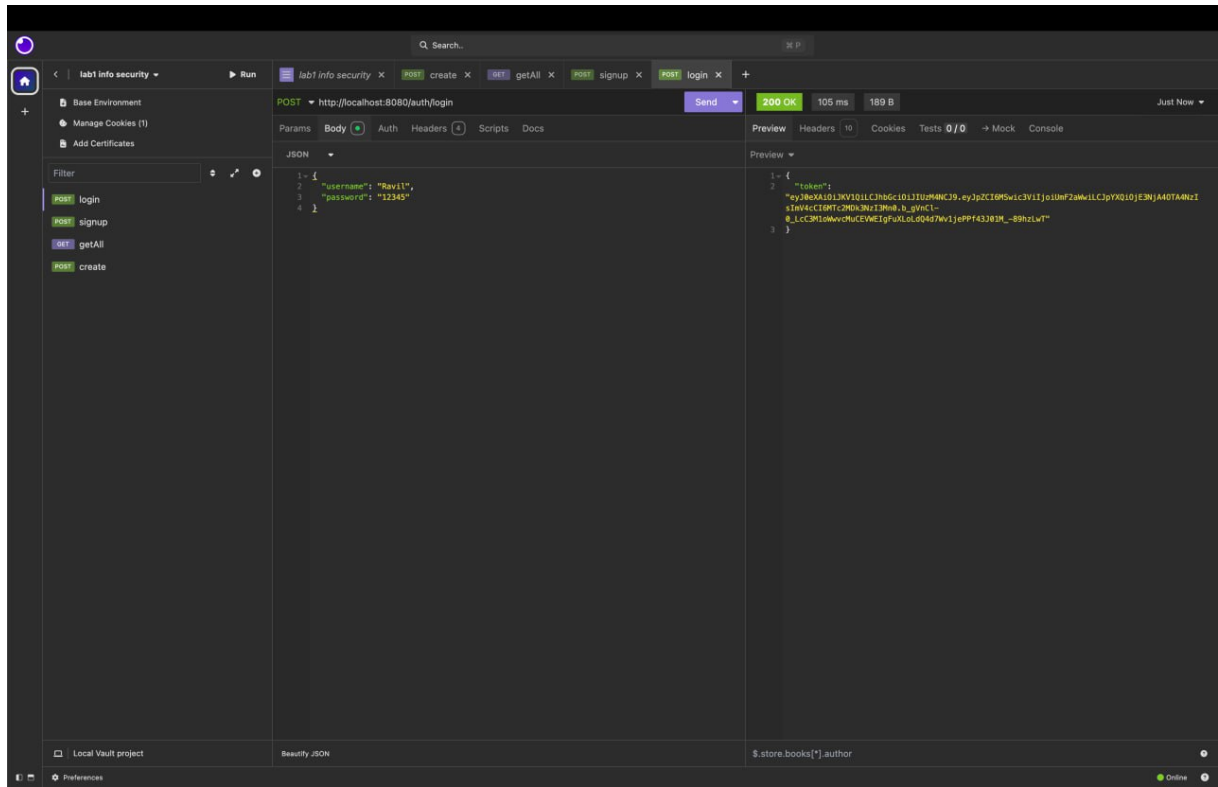
Результат SpotBugs

```
<FindBugsSummary num_packages="8" total_classes="22" total_size="365" clock_seconds="3.15"
referenced_classes="179"
    vm_version="21.0.8+9-LTS" total_bugs="0" java_version="21.0.8" gc_seconds="0.03"
alloc_mbytes="512.00"
    cpu_seconds="10.33" peak_mbytes="228.89" timestamp="Sun, 19 Oct 2025 14:03:07
+0000">
```

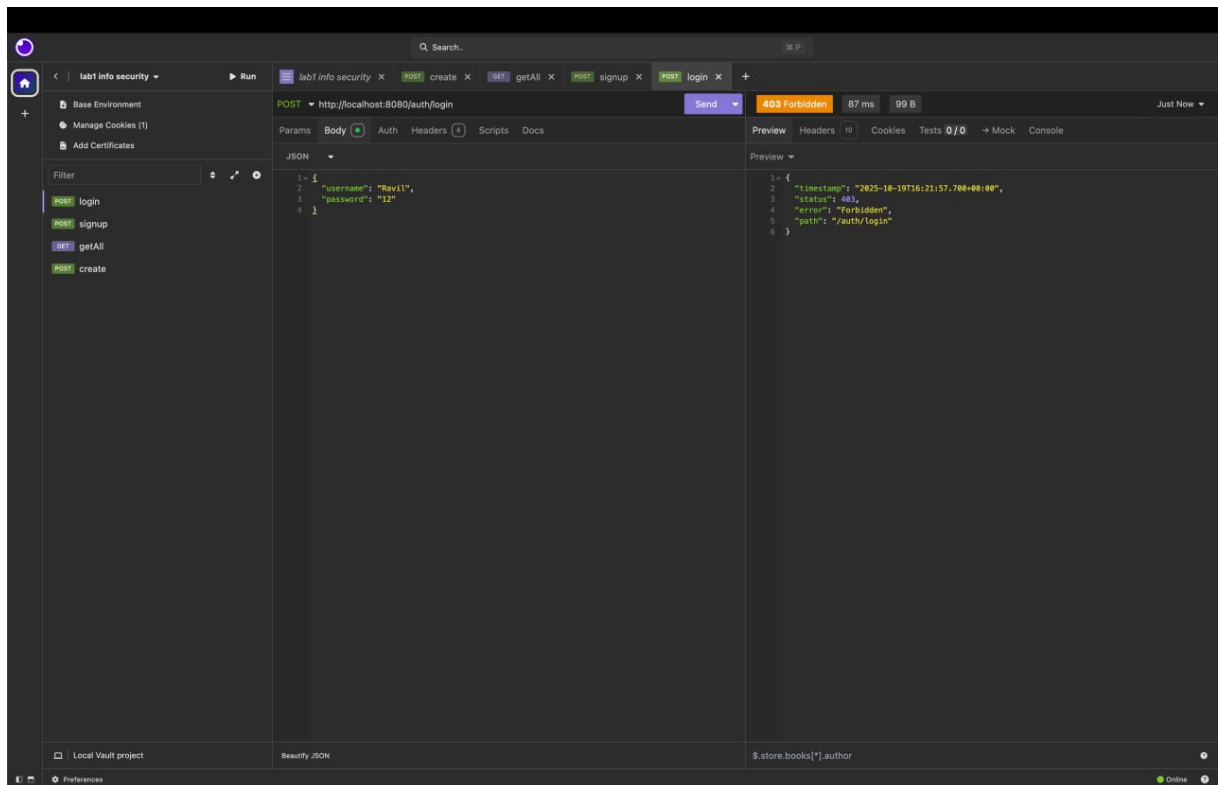
Тестирование приложения

Авторизация:

Корректные данные:

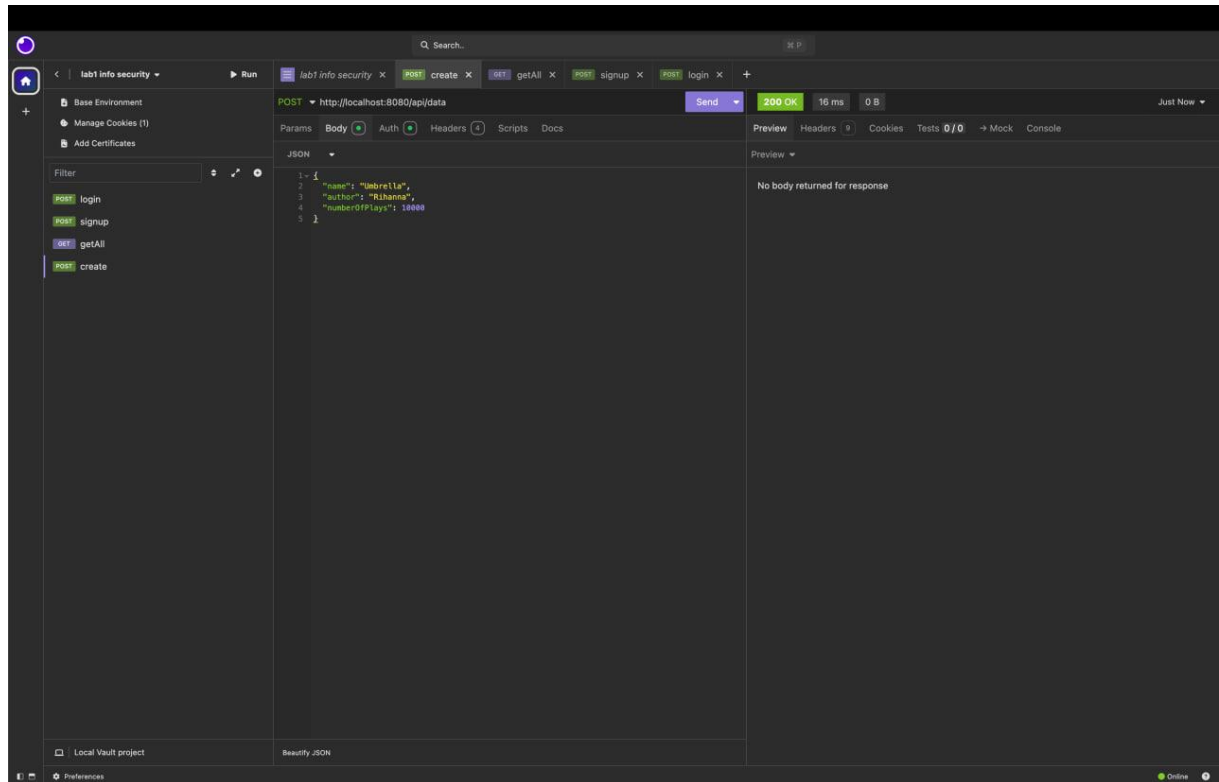


Некорректные данные:

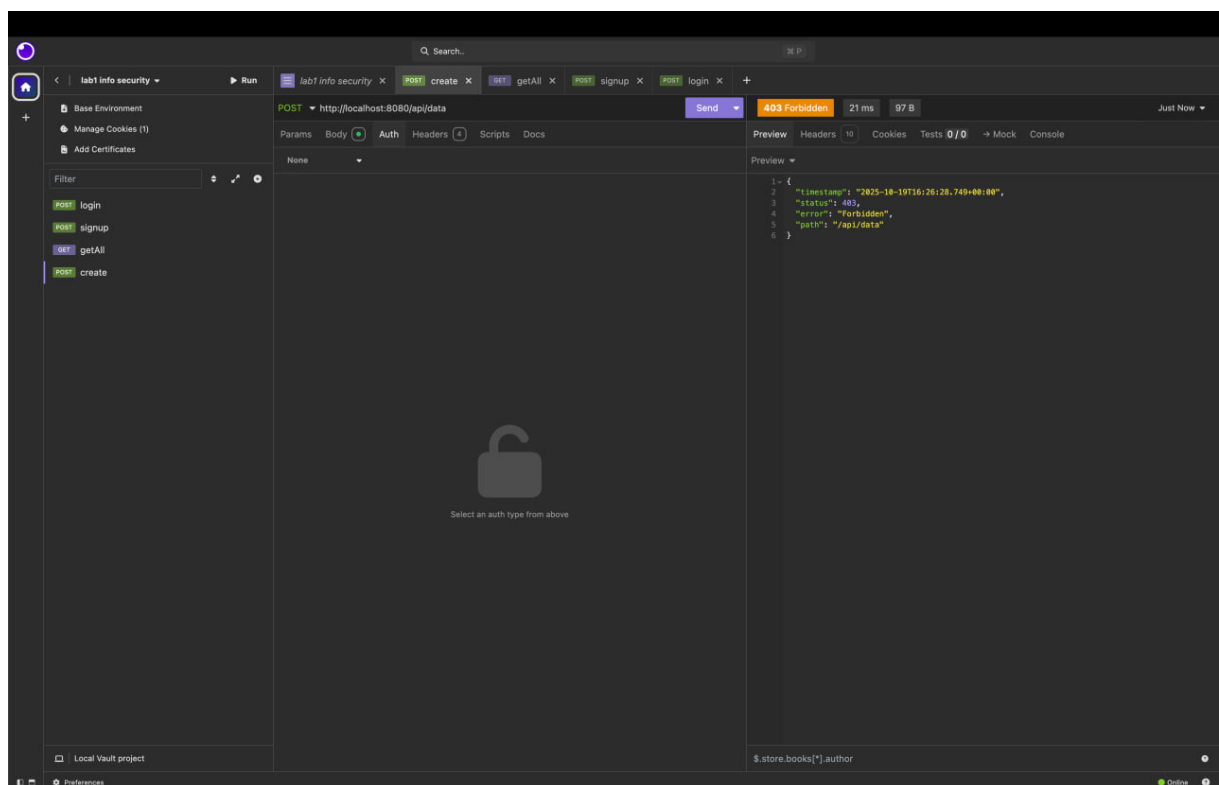


Добавление нового трека:

Авторизованный доступ:

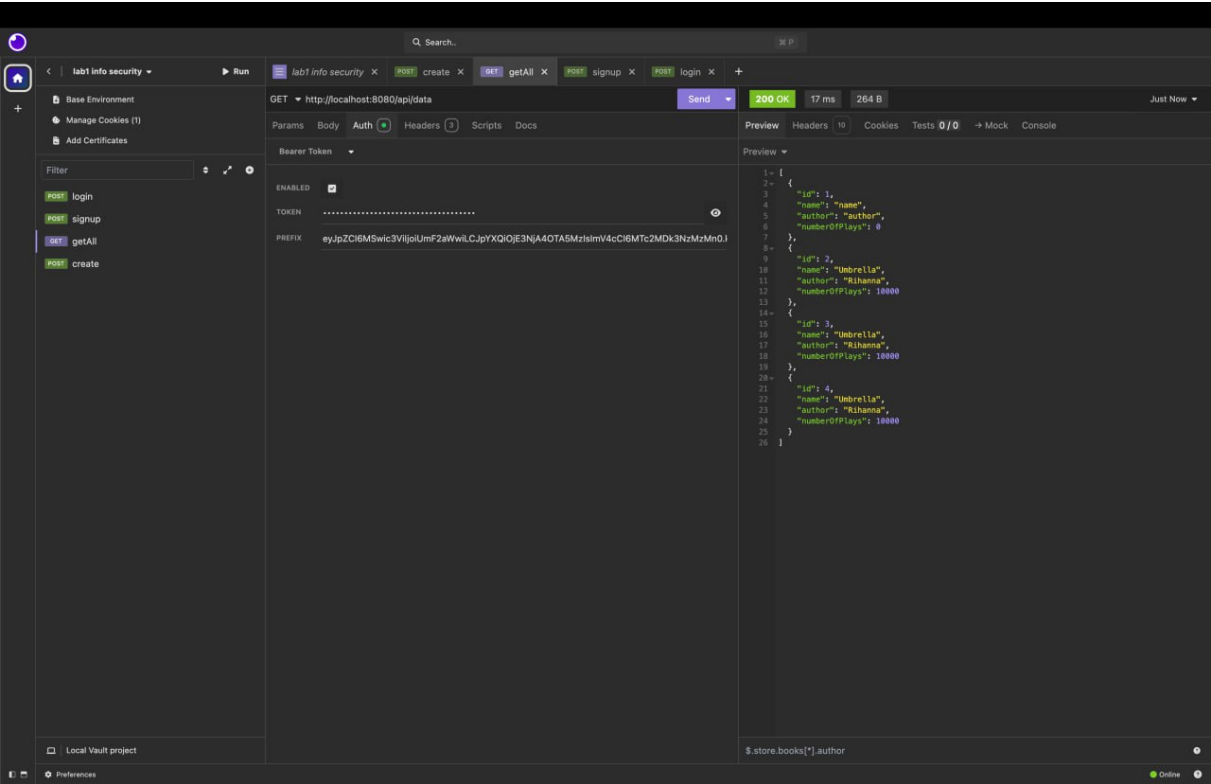


Неавторизованный доступ:

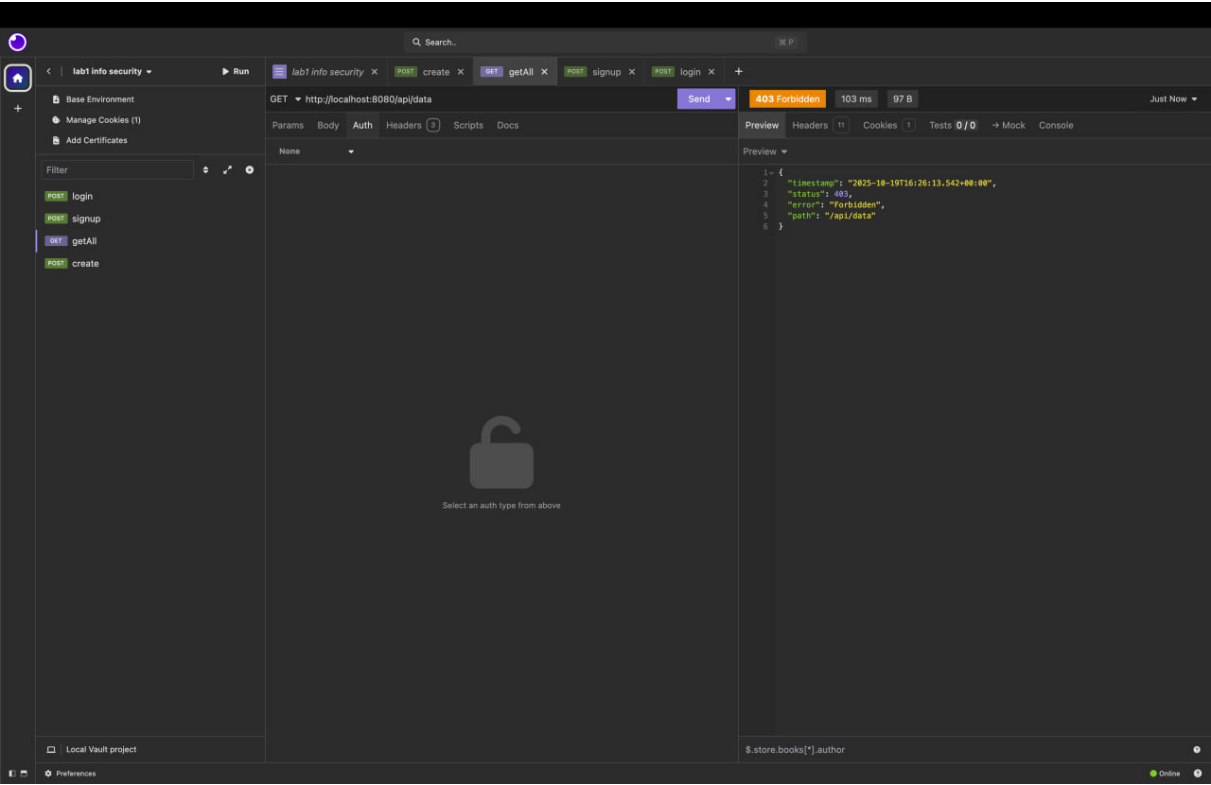


Получение списка треков:

Авторизованный доступ:



Неавторизованный доступ:



**Ссылка на последний успешный запуск pipeline в
вашем репозитории**

<https://github.com/RavvChek/lab1/actions/runs/18631473006/job/53116774377>

Вывод

Выполнив данную лабораторную работу, я научился разрабатывать защищенный REST API. Применяв все необходимые практики защиты собственных приложений, я освоил навык создания безопасных веб-сервисов.